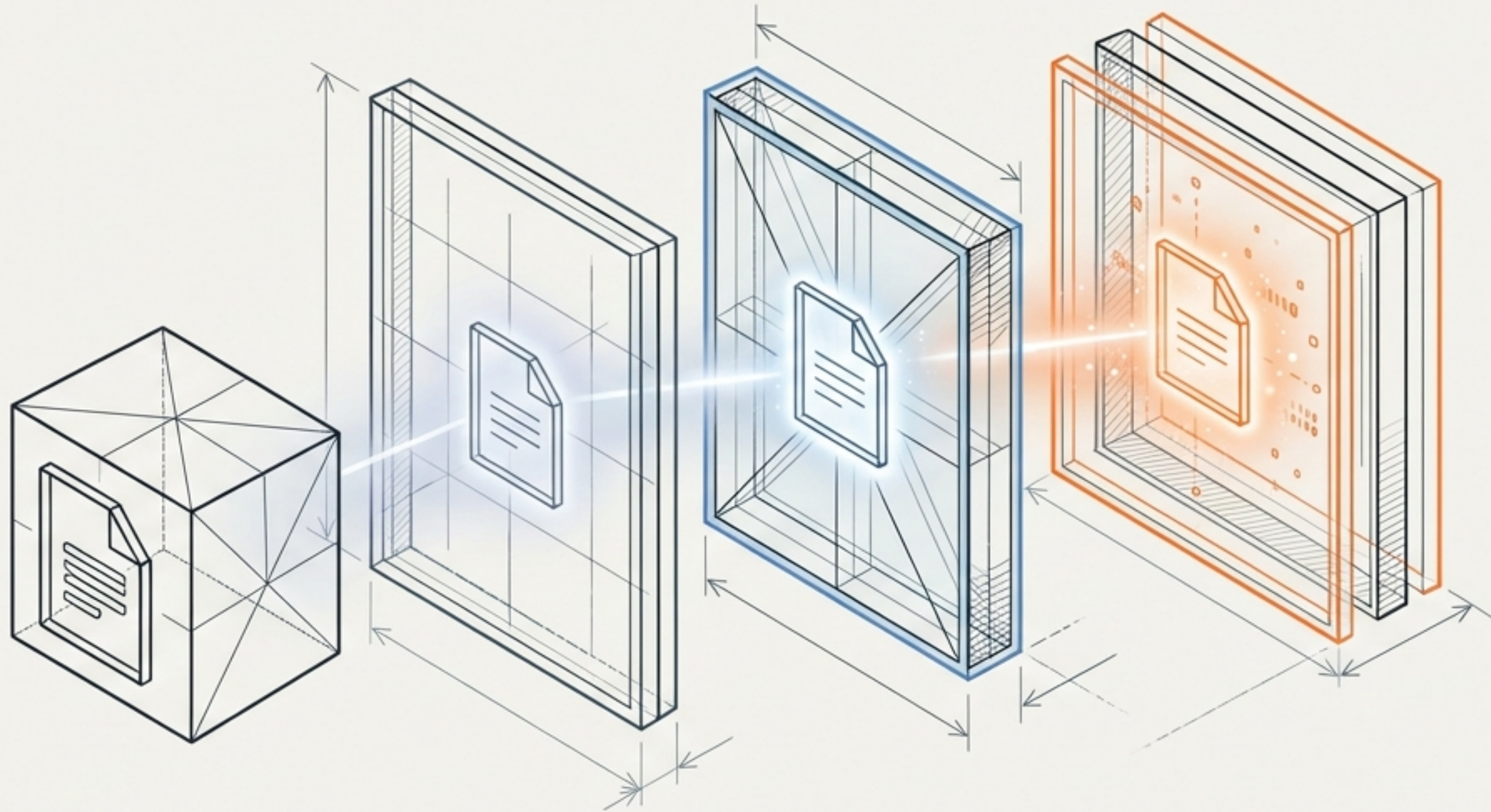
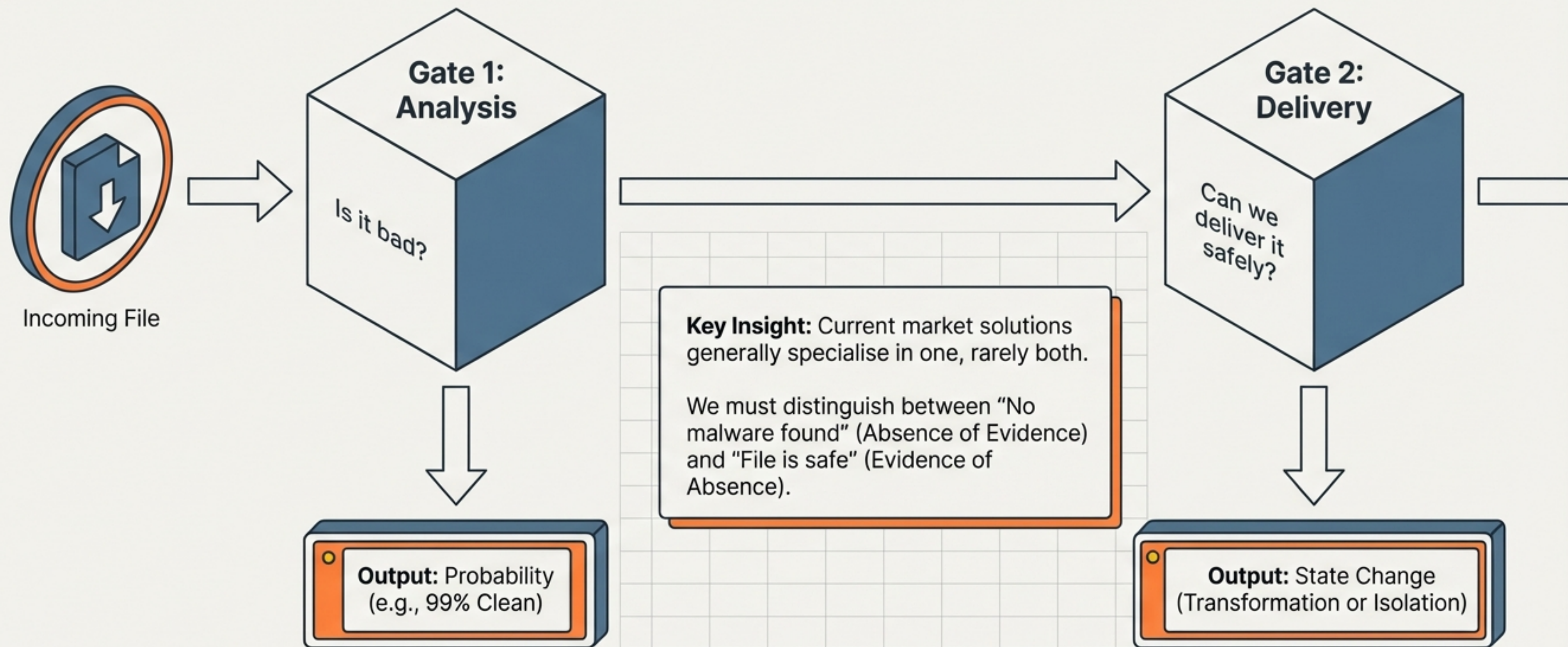


File Security Services Landscape

Market Survey & Architectural Fit for the PKI-Verified Chain

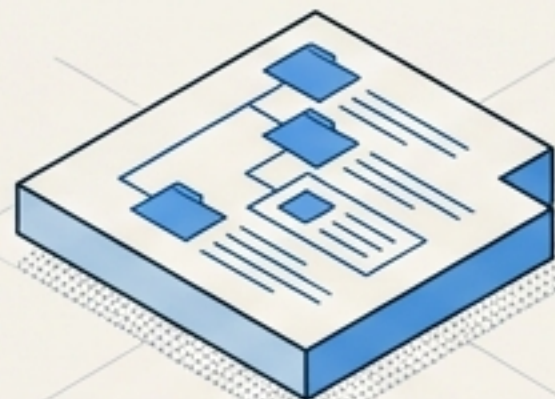


The Pipeline Asks Two Distinct Questions



The Spectrum of Scrutiny: From Hashing to Heuristics

Froing Helveticain Helvetical



Fast / Cheap / Surface

Reputation & Network Signals

Mechanism: Checks file hash against databases.

Examples: VirusTotal hash lookup, NSRL (NIST), MalwareBazaar.

Moderate / Deep

Static Analysis

Mechanism: Analyses structure (macros, scripts) without execution.

Examples: YARA rules, ClamAV, oledtools (Office-specific).

Slow / Expensive / Predictive

Dynamic & AI

(See next slides).

Analysis: Reputation and Static analysis form the 'First Line of Defence'. They offer high-speed, low-latency filtering to drop known bad files instantly, but remain blind to zero-day threats.

Dynamic Execution and Multi-Engine Consensus



Multi-Engine Scanning

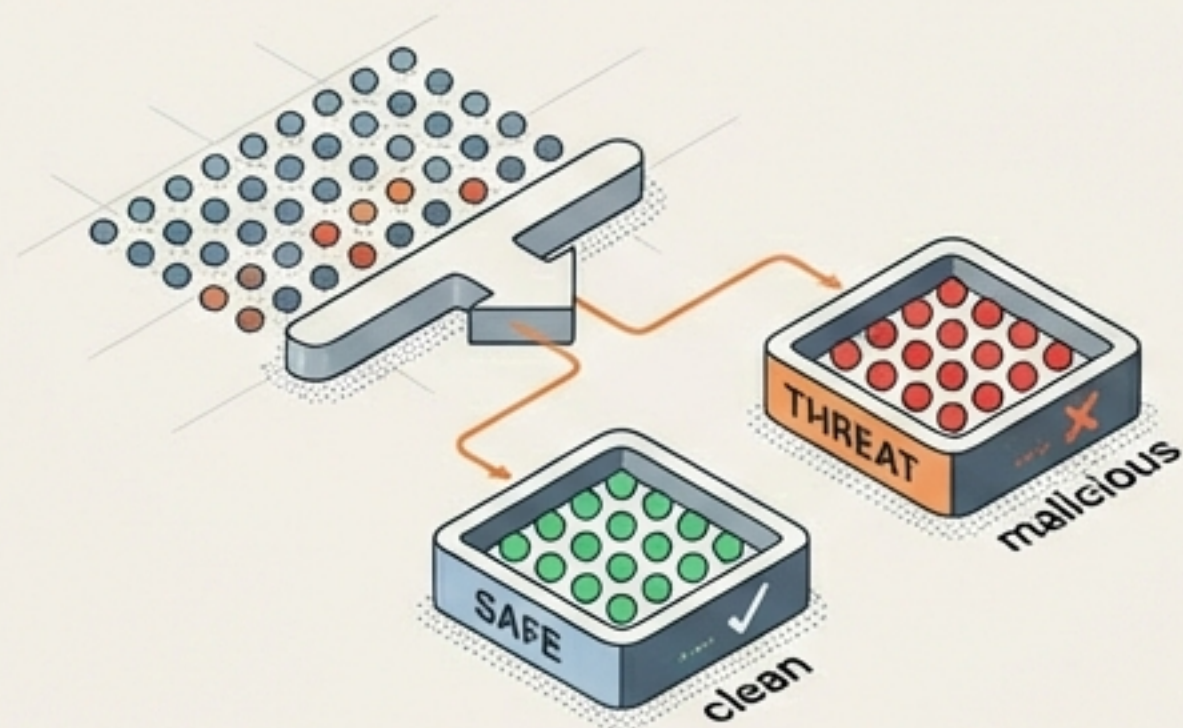
- Runs the file against dozens of antivirus engines simultaneously.
- **Vendors:** VirusTotal, MetaDefender (OPSWAT), Jotti.
- **Result:** Broad coverage, but creates a 'probability' score rather than a binary yes/no.

Sandbox / Dynamic Analysis

- Executes the file in an isolated environment to observe behaviour.
- **Vendors:** Cuckoo Sandbox, Hybrid Analysis (CrowdStrike), Joe Sandbox, ANY.RUN.
- **Critical Critique:** Sandboxing is the gold standard for detection accuracy but constitutes the primary bottleneck for User Experience (latency).

The AI Frontier: Moving From Classification to Explanation

Established ML Classification



- **Focus:** Trained on malware datasets to detect patterns.
- **Vendors:** Cylance, Carbon Black, Academic models.
- **Status:** Mature, Commercialised.

The LLM Opportunity (Greenfield)



- **Focus:** Analysing extracted code, macros, and scripts for intent.
- **Status:** **NOVEL**. No major commercial offering yet.
- **Source Note:** Identified in scanning pipeline brief as a high-value opportunity for custom development.

Transformation: Disarming the Payload



Content Disarm and Reconstruction (CDR)

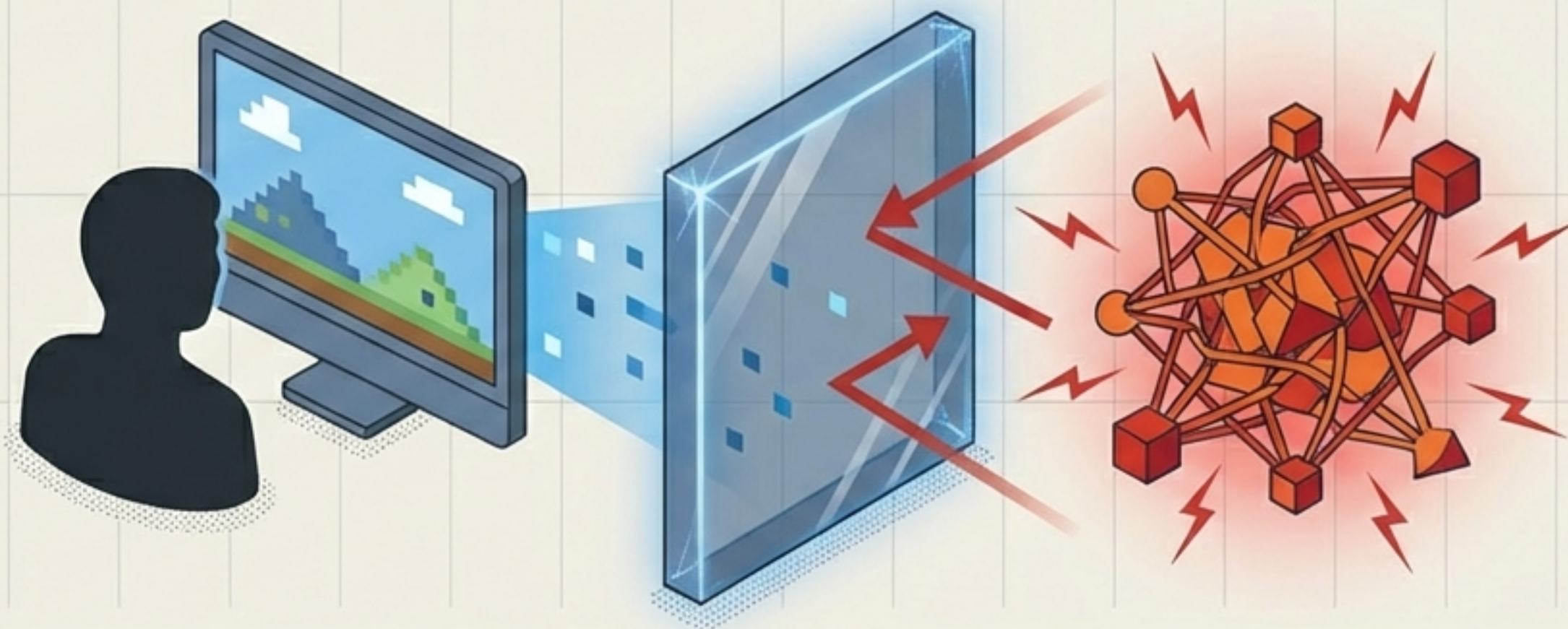
- **Method:** Strips potentially dangerous elements and reconstructs
- **Vendors:** Votiro, OPSWAT Deep CDR, Glasswall, Sasa Software.
- **Capability:** Can accept a file and return a sanitised version via API.

File Format Conversion

- **Method:** Flattens dynamic content (e.g., DOCX to PDF to Flat PDF).
- **Tools:** LibreOffice headless conversion.
- **Tools:** LibreOffice headless conversion.

Use Case: Best for direct downloads where the user needs a physical file, not just a view.

Isolation: The Glass Wall Approach



Secure Browser Isolation

- **Method:** Renders content in a remote browser; streams pixels to the user.
- **Vendors:** Surf Security, Menlo Security, Cloudflare Browser Isolation, Authentic8 Silo.
- **Integration:** Suitable for high-security receivers.

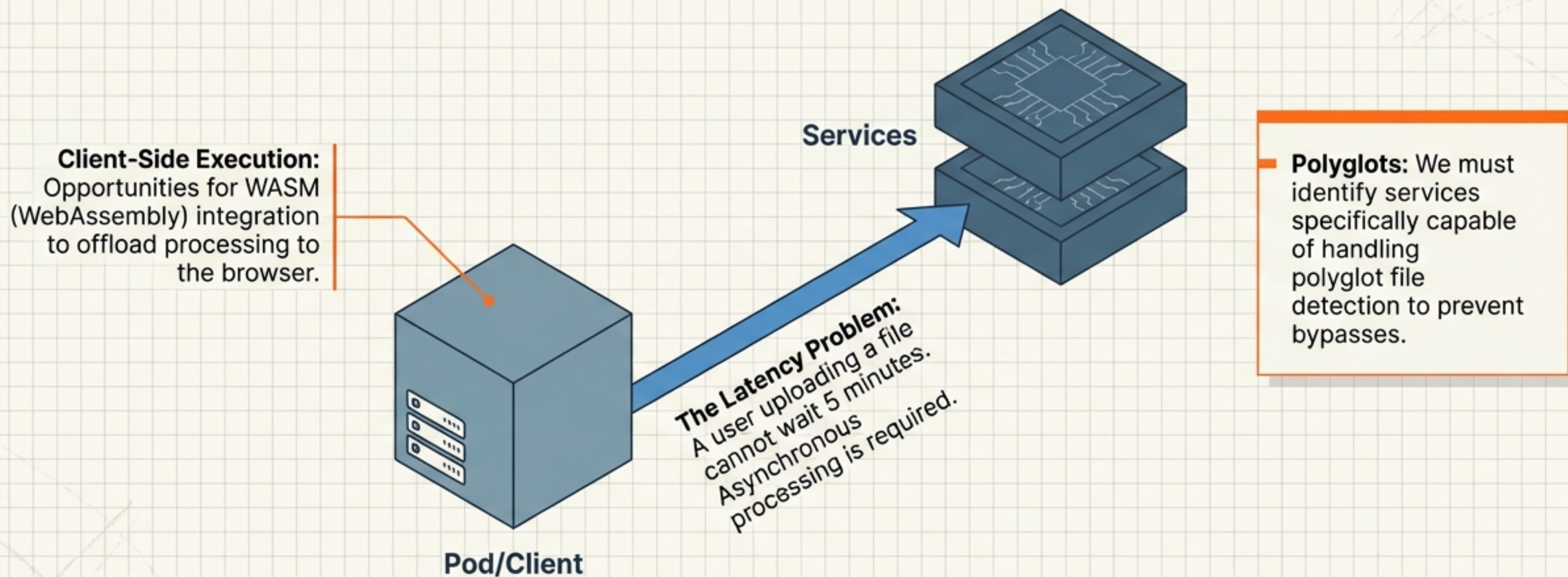
Micro-Virtualisation

- **Method:** Opens file in a micro-VM on the endpoint.
- **Vendors:** HP Sure Click, Bromium (legacy).

Trade-off

- High security, but potentially higher friction or cost per user.

The Integration & API Logistics



Implementation of asynchronous API calls is critical for seamless user experience.

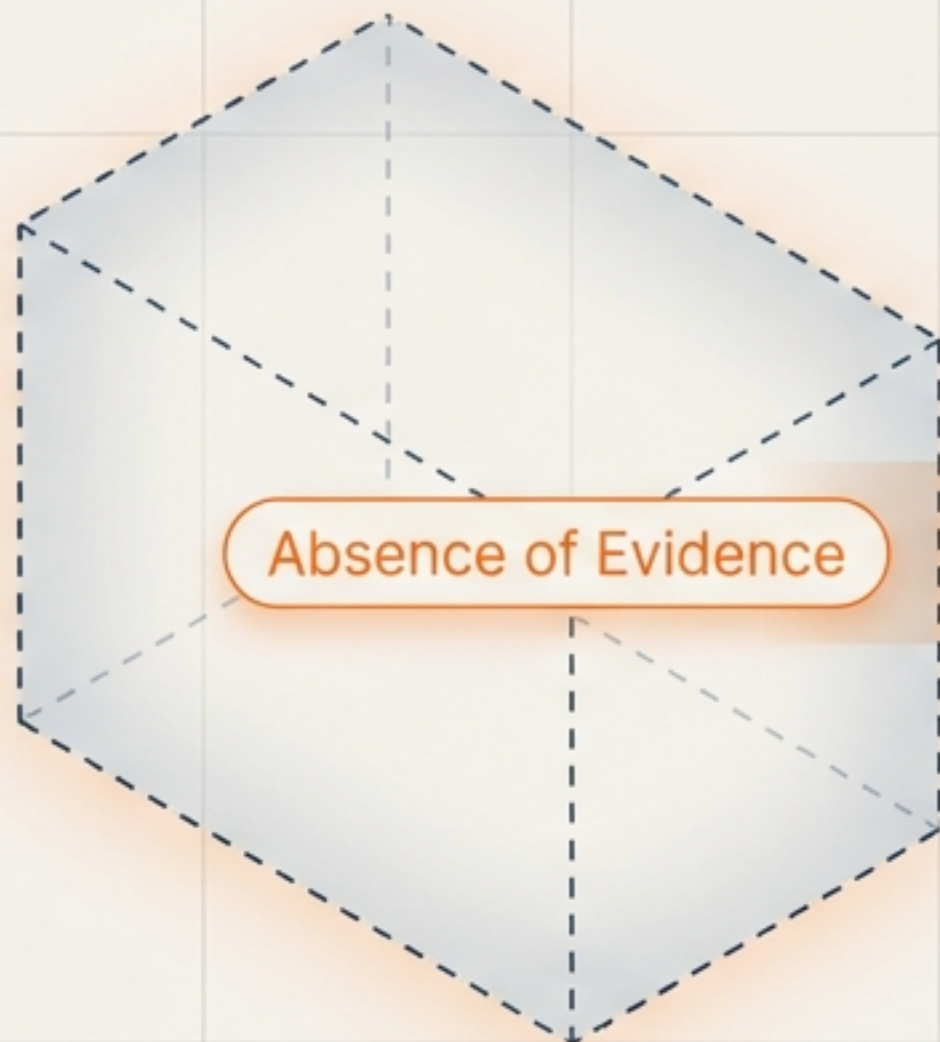
The Trust Gap: Evidence of Absence

The Problem

Most services provide “Absence of Evidence” (We didn’t find anything). We need “Evidence of Absence” (Positive confirmation of safety).

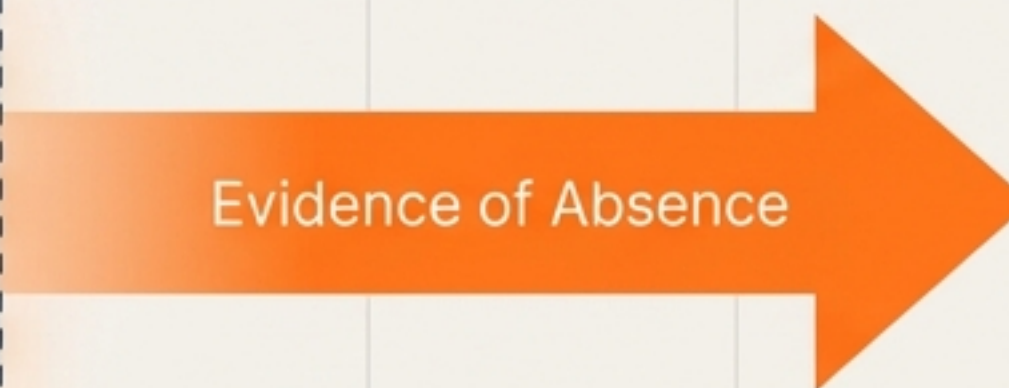


Vendor Result



The Signing Issue

- Research indicates most services do not produce PKI-signed results today.
- Architectural Requirement: We must “wrap” these services. The pipeline itself must sign the result after receiving the vendor’s JSON verdict.



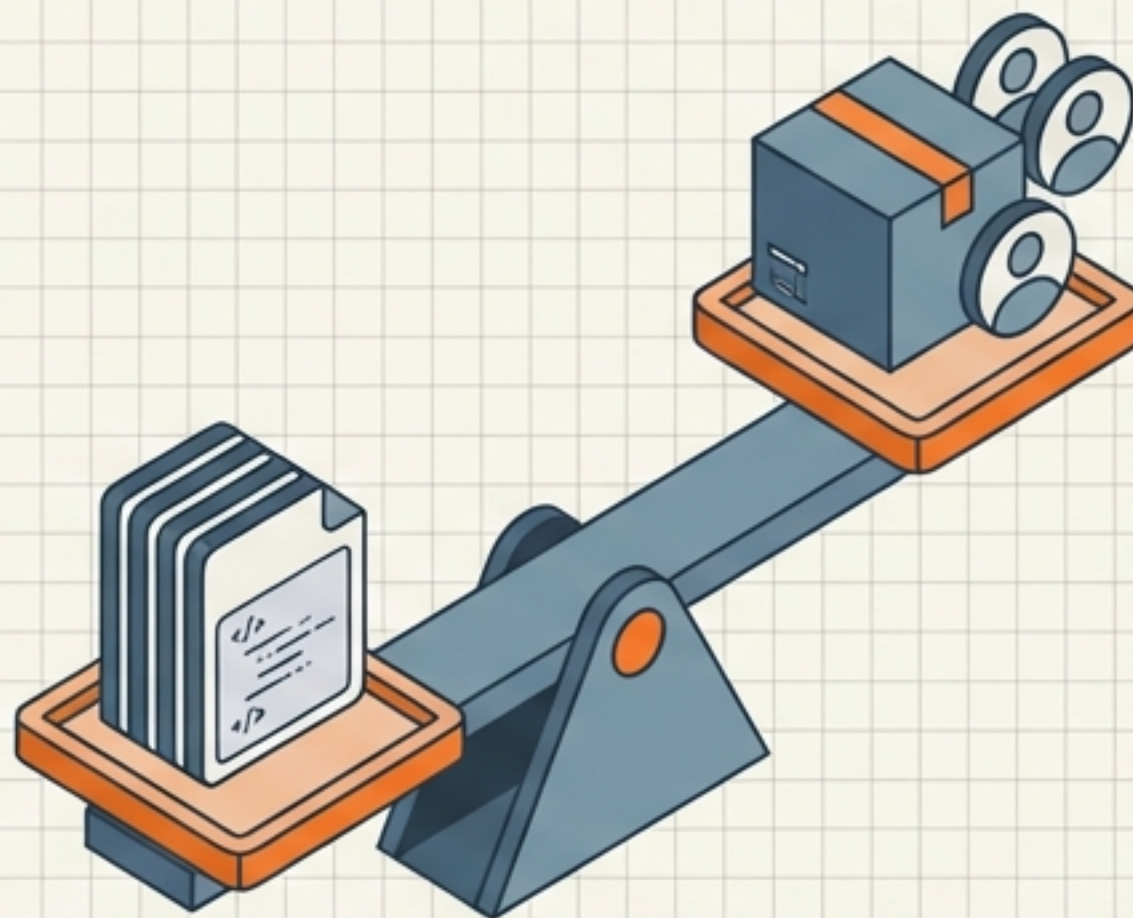
Chain of Custody

Commercial Models & Cost Implications

Model A: Per-File / Per-GB

Directly maps to the 'Sender Pays' architecture.

Risk: Cost spikes during high-volume attacks or spam.



Model B: Subscription / Seat

Predictable for enterprise use, but harder to attribute to external senders.

Strategic Question: How do we model cost when the sender is paying? We may need a hybrid approach where base scanning is covered, and premium scanning (Sandbox) is a 'paid' tier.

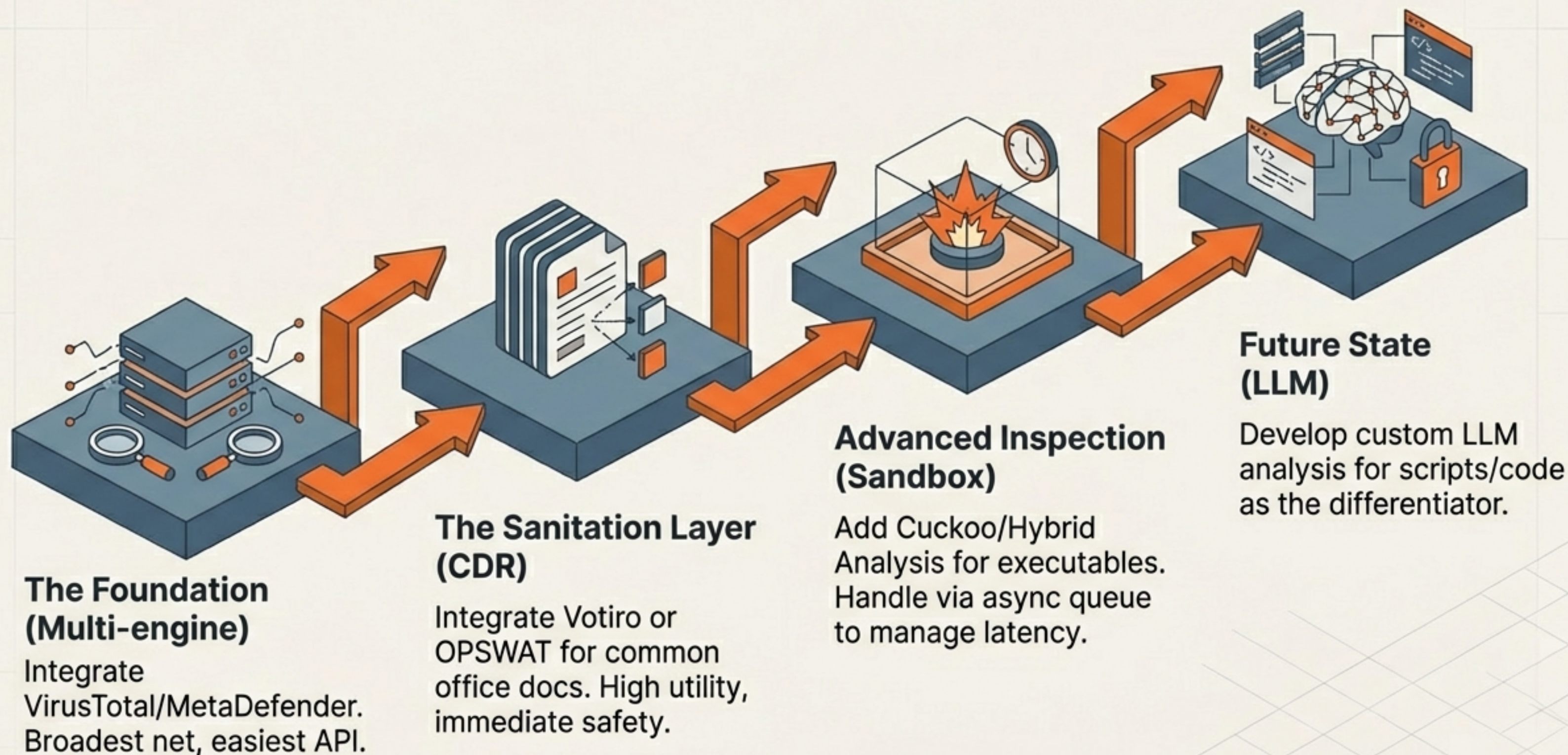
Capability Comparison Matrix

	Detection Accuracy	Latency	API Maturity	Cost Model	Evidence of Absence?
Multi-engine	 High	 High	 High	 High	 No
Sandbox	 High	 High	 High	 High	 No
Static	 Low	 Low	 High	 Low	 No
Reputation	 Low	 Low	 High	 Low	 No
AI/ML	 High	 Low	 High	 High	 No
CDR	 High	 Low	 N/A	 High	 No
Isolation	 High	 Low	 N/A	 High	 No

No single vendor creates a “Green” row across the board.
Orchestration is mandatory.

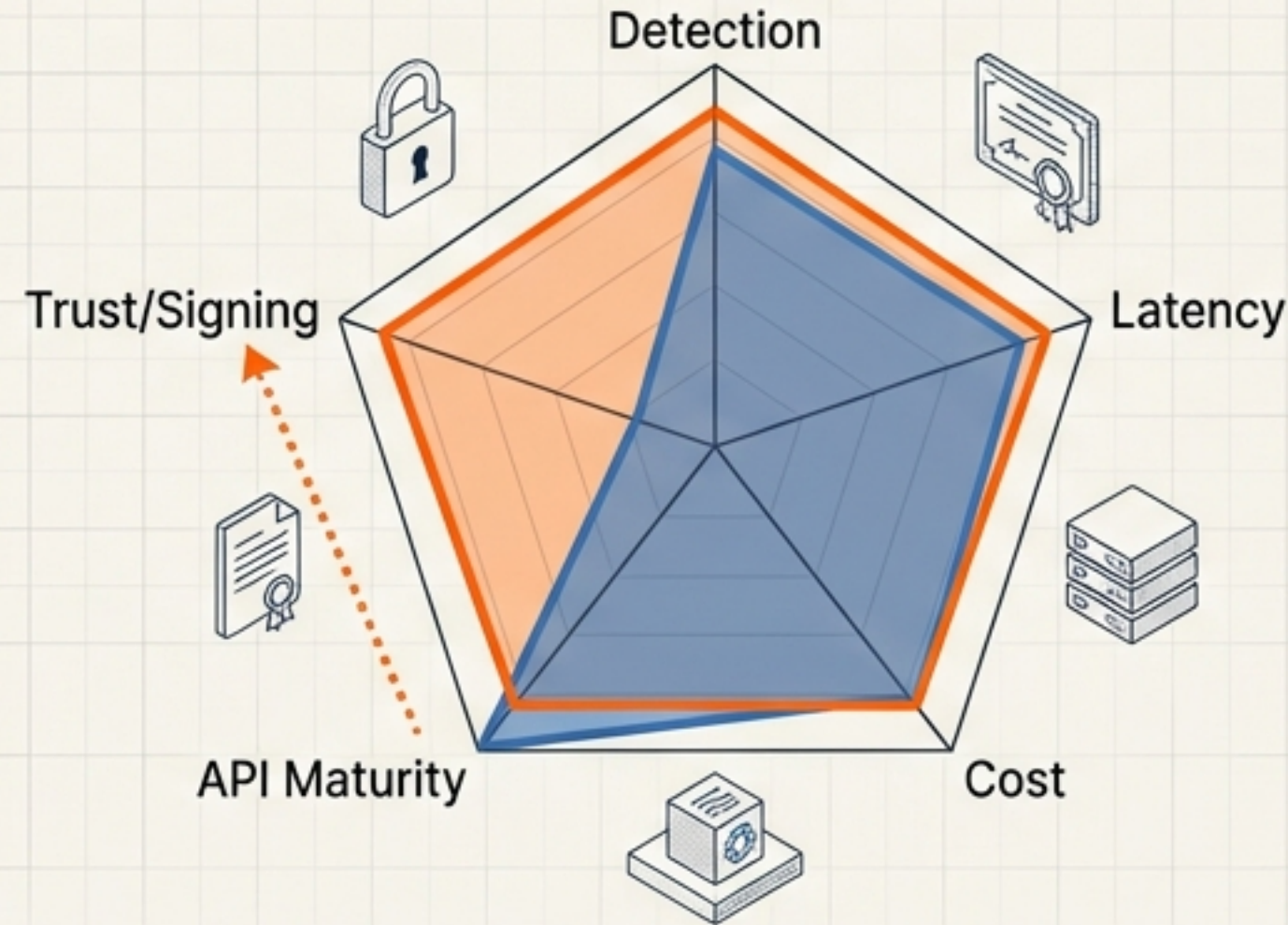


Recommended Integration Roadmap



Conclusion: The Orchestrator is the Value

Market Strength vs. Our Architectural Needs



Key Takeaways:

- **Commodity:** Multi-engine scanning is accessible and commoditised.
- **The Gap:** 'Evidence of Absence' (Certified Safety) is missing from the market.
- **The Strategy:** Our value is not in scanning, but in the chain of custody—wrapping these noisy signals into a single, PKI-signed verdict that the user can trust.
- **Next Steps:** Begin API trials with Step 1 vendors and prototype the 'Wrapper' service for PKI signing.